Westlands Business Park, Nairobi, Kenya
+254 20 123 4567
info@jscapital.co.ke
www.jscapital.co.ke

PHISHING INCIDENT RESPONSE PLAN

1. PURPOSE AND OBJECTIVES

This Phishing Incident Response Plan ("IRP") establishes how JS Capital Limited will receive, assess, contain, eradicate and recover from suspected or confirmed phishing incidents. It provides employees with a clear reporting route and gives responders a practical sequence of actions to reduce harm, preserve evidence, restore affected services and learn from incidents.

The primary objectives of this IRP is to:

1. Enable prompt and safe reporting of suspicious messages.
2. Determine whether a message is malicious and whether a user, account, device, system or information asset has been affected.
3. Prioritise incidents according to actual or reasonably suspected impact.
4. Limit unauthorised access, data disclosure, financial loss and business disruption.
5. Preserve relevant evidence and maintain an auditable incident record.
6. Restore affected accounts, devices and services safely.
7. Identify lessons and assign corrective actions.

2. COMPANY PROFILE

JS Capital Limited is an investment banking company for equities and fixed income trading in the Nairobi Securities Exchange (NSE) ("the Company"). The Company comprises of 32 employees. Its system comprises of the following:

1. Microsoft 365
2. Employee Laptops
3. Employee Mobile Devices
4. Internet access
5. Endpoint protection
6. Multi-Factor Authentication

The Company has a small IT department that performs technical response. The IT department has established a phishing email checker, a tool that checks for a defined set of suspicious indicators, explains each indicator and produces a cautious risk summary.

3. SCOPE

This Plan applies to:

a. Deceptive emails impersonating employees, suppliers, customers, banks or service providers;
b. Credential-harvesting links or fake login pages;
c. Suspicious attachments;
d. Business email compromise, including unauthorised mailbox access, forwarding rules or payment diversion; and
e. Phishing campaigns affecting multiple employees.

It does not replace wider cyber incident response, business continuity, disaster recovery, physical security or general data breach procedures. If investigation identifies a broader compromise, the Incident Response Lead (IRL) must escalate and activate the relevant wider procedure.

4. DEFINITION AND RESPONSE PRINCIPLES

Term	Meaning
Phishing	A deceptive message intended to induce a recipient to click, open, disclose information or take an unauthorised action.
Suspected incident	A report or activity that may involve phishing but is not yet confirmed.
Confirmed incident	An event supported by evidence of malicious content, credential disclosure, unauthorised access or related compromise.
Containment	Immediate action to limit further harm, such as quarantining a message, disabling an account or isolating a device.
Eradication	Removing the cause and attacker persistence, such as malicious files, unauthorised mailbox rules or attacker access.
Recovery	Safely restoring affected accounts, devices and services, with appropriate monitoring.
Evidence	Original emails, headers, logs, timestamps, screenshots, user statements and response records.

- Protect people, information and business operations; do not delay urgent containment while waiting for every fact.
- Do not click suspicious links, open suspicious attachments, reply to the sender or test a suspicious URL from an ordinary workstation.
- Use independently verified contact details and trusted communication channels.
- Record facts, assumptions, decisions, actions, timestamps and responsible persons.
- A click alone does not prove compromise; deleting an email alone does not prove eradication.
- Limit access to evidence and personal information to authorised people with a need to know.

5. ROLES AND RESPONSIBILITIES

Role	Responsibilities
Employee / reporter	Report promptly; do not interact further; state what actions were taken; preserve the message where possible; follow IT instructions.
IT Administrator	Log and investigate reports; inspect message details and available logs; check recipients, sign-ins, mailbox rules and endpoint alerts; perform authorised response actions.
Incident Response Lead	Coordinate response; maintain incident record; assign/review severity; convene responders; escalate to management; oversee closure and lessons.

Management	Approve significant business decisions, expenditure, service interruption and external communications; provide resources; oversee material risk.
HR / Communications	Support staff communications and employee coordination where required.
Legal / Data Protection adviser	Advise on confidentiality, personal data breach assessment, contractual obligations, evidence and notification decisions.

6. REPORTING AND ACTIVATION

6.1 Employee reporting

- Employees must report suspicious messages as soon as possible through the Incident Reporting Tab on the Phishing Email Checker.
- For suspected account compromise, financial fraud or disclosure of credentials, the employee must also contact it@jscapital.com immediately.
- The report should include the original email, sender address, subject, time received, affected mailbox, and whether the recipient clicked a link, opened/downloaded an attachment, replied, disclosed information, approved an MFA request or made a payment.
- Employees must not forward suspicious messages to colleagues for informal review, visit links to test them, enter credentials, or delete the message before reporting unless instructed. If they have already interacted with the message, they must report that fact immediately.

6.2 Activation and escalation

- The IT Administrator logs every report as a suspected incident. The IRL must be notified immediately where credentials or MFA information may have been disclosed, suspicious code may have executed, unauthorised account activity is suspected, a payment instruction may have been acted upon, sensitive information may have been exposed, or multiple users may be affected.

- The Plan is activated when the IRL determines that coordinated response is required. Urgent containment may begin before formal activation if delay could increase harm. The IRL records activation time, initial severity, response lead and persons notified.

7. SEVERITY CLASSIFACTION AND ESCALATION

- The IRL assigns an initial severity using the highest credible impact known at the time. Severity must be reviewed as new evidence emerges. The Phishing Email Checker score is a triage signal only and the severity depends on what happened and the resulting or reasonably suspected impact.

Level	Typical indicators	Required response
LOW	Message received only; no interaction; no evidence of compromise.	IT reviews, checks recipients, quarantines confirmed malicious copies and records outcome; routine IRL update.
MEDIUM	Link clicked or attachment opened, but no known disclosure or confirmed compromise.	Prompt IT and IRL notification; establish actions; review endpoint/account activity; assess downloads/execution; monitor and contain if indicated.

HIGH	Credentials/MFA disclosed; suspicious sign-in/mailbox activity; malware may have executed; sensitive data or payment details may be exposed.	Immediate IRL and management escalation; contain account/device; reset credentials/revoke sessions; investigate and assess impact; consider legal/privacy advice.
CRITICAL	Multiple accounts/systems compromised; material data exfiltration; successful fraudulent payment; major disruption or serious harm.	Immediate management-led coordination; urgent containment; consider external response, legal/privacy support, bank contact and business continuity.

- If uncertain, apply the higher level temporarily. Only the IRL or management delegate may downgrade a High or Critical incident, and the rationale must be recorded.

8. OPERATIONAL RESPONSE PROCEDURE

8.1. PHASE 1 – PREPARATION

Personnel	Action	Output
IT Administrator, coordinated by the IRL	Maintain a monitored reporting channel and out-of-band emergency contact method. Maintain current contact details for IT, IRL, management, legal/privacy adviser and service providers. Confirm who is authorised to quarantine messages, disable accounts, reset passwords, revoke sessions, review sign-in logs and isolate endpoints. Confirm MFA coverage, endpoint protection, administrative access controls and backup/recovery arrangements. Maintain a restricted incident register and secure evidence storage. Provide staff with practical instructions on identifying and reporting suspicious messages. Ensure responders can access administration consoles and logs without relying on a potentially compromised account.	Current contact list Reporting route, Authority list, Incident register and Staff guidance.

8.2. PHASE 2 – IDENTIFICATION AND INITIAL ASSESSMENT

Personnel	Action	Output
IT Administrator Severity decision to be made by the IRL	Create an incident ID (e.g. PH-2026-001) and record report time, reporter, affected user and message details. Ask what happened: received only, clicked, opened, downloaded, replied, entered credentials, approved MFA, disclosed information or made a payment. Preserve the original message and available headers. Record sender, reply-to, subject, timestamps, displayed URLs and attachment names. Do not visit URLs or open suspicious files. Run the Phishing Email Checker as a triage aid. Record its findings and score, but independently assess the email and context.	Incident record, Provisional severity, Affected-user/device list and Containment decision.

	Check whether other employees received the same or similar message and whether anyone interacted with it. Review available email alerts, sign-in activity, mailbox rules, endpoint alerts and user reports. Assign provisional severity using Section 7 and Appendix 3. Separate confirmed facts from assumptions and unanswered questions. If evidence suggests compromise, begin containment immediately; do not wait for every investigative question.	

- Initial assessment questions: Who received it? When? What did the user do? Which account/device is involved? What information or access may have been exposed? Are others affected? Is there evidence of unauthorised access, persistence, data access or financial loss?

8.3. PHASE 3 – CONTAINMENT

Personnel: IT Administrator, coordinated by IRL. It is prudent to record each action, reason, time, person responsible and result.

A. Message received - no interaction

- Tell the user not to click, reply, open attachments or forward the message.
- Preserve the original message and relevant headers.
- Search for matching messages in other mailboxes and quarantine/remove confirmed malicious copies using authorised tools.
- Block sender, domain, URL or attachment indicators only when sufficiently verified and appropriate; avoid broad blocks that may disrupt legitimate business.
- Notify potentially affected users if the campaign reached multiple recipients.

B. Link clicked - no known credential disclosure

- Contact the user through a trusted channel; establish time, device, browser and exact actions.
- Ask whether a file downloaded, a prompt appeared, credentials were entered or MFA was approved.
- Review endpoint alerts, relevant download information where authorised, and account sign-in logs.
- If malware execution or device compromise is suspected, isolate the device using approved procedures while preserving it. Do not power it off unless the technical procedure or response lead directs this.
- Check whether the same message/URL affected others; quarantine matching messages and monitor the account/device.
- Do not classify a click alone as confirmed compromise without supporting evidence.

C. Credentials/MFA disclosed or account compromise suspected

- Escalate immediately to IRL and management; use a trusted device and verified administrative channel.
- Reset affected password and any other credentials that may have been reused. Do not send replacement credentials through the suspicious email thread.
- Revoke active sessions, refresh tokens or sign-in sessions where the platform supports it.
- Review MFA methods, authentication activity, unfamiliar devices/locations, mailbox rules, forwarding, delegates, connected applications and authorised devices.
- Record relevant evidence before removing unauthorised rules, sessions, applications or access where practicable; then remove them using authorised procedures.

- Check for messages sent from the compromised account, especially payment, gift-card, credential or sensitive-information requests.
- Warn recipients of fraudulent messages and verify payment instructions through a separate trusted channel.
- If bank/payment information may be compromised or a fraudulent transfer is suspected, contact the financial institution immediately using independently verified details.
- Consider isolating the associated endpoint if there is evidence of malware or device compromise.

D. Personal or confidential information may have been disclosed

- Identify the type and approximate volume of information, whose information it relates to, and whether access/disclosure is confirmed or suspected.
- Restrict further access and preserve relevant logs and communications.
- Notify IRL, management and legal/data protection adviser promptly for a documented assessment.
- Do not make external or regulatory notifications without authorised review, except where an applicable legal obligation or approved procedure requires urgent action.
- Containment is achieved when the immediate pathway for further harm has been interrupted to a reasonable degree (e.g. messages quarantined, sessions revoked, credentials reset or device isolated). Containment does not mean the root cause has been removed.
- Output: containment actions, timestamps, responsible persons, affected users/accounts/devices and remaining risks.

8.4. PHASE 4 – ERADICATION

Personnel: IT Administrator, overseen by IRL.

- Remove/quarantine malicious messages across affected mailboxes and identify remaining copies.
- Remove malicious files/software using approved endpoint procedures. If device integrity cannot be trusted, rebuild from a known-good image under IT policy.
- Remove unauthorised forwarding, inbox rules, delegates, app permissions or other persistence mechanisms.
- Reset affected credentials, revoke sessions and remove unauthorised authentication methods/devices.
- Address the initial weakness where practicable, such as inadequate MFA coverage, weak account recovery, unsafe mail rules or insufficient filtering.
- Search for related indicators and assess whether the campaign affected other users/systems.
- Record what was removed, how removal was verified and unresolved concerns.
- Do not mark the incident eradicated merely because the original email was deleted. Consider whether an attacker retains access or malicious content remains elsewhere.

8.5. PHASE 5 – RECOVERY

Personnel: IT Administrator; closure approval by IRL.

- Confirm affected accounts are under authorised control, passwords reset, sessions revoked and MFA methods reviewed.
- Confirm unauthorised mailbox rules, delegates, app permissions and devices have been removed.
- Confirm affected endpoints have been scanned and cleaned or rebuilt, and security controls function.
- Restore access and business services in a controlled manner; obtain user confirmation that normal work can resume.
- Monitor for repeat sign-ins, new forwarding rules, unusual outbound messages, unexpected MFA prompts or other renewed compromise indicators.

- Provide users with clear instructions and awareness guidance where appropriate.
- Document residual risk and obtain management acceptance where risk cannot be fully eliminated.
- Recovery is complete only when services can safely return to normal, required controls are restored, monitoring is in place and outstanding risks are documented.

8.6. PHASE 6 – POST-INCIDENT REVIEW

Personnel: IRL.
Conduct after containment and recovery, while facts remain fresh.

- Reconstruct the timeline from receipt through reporting, decisions, containment, eradication and recovery.
- Identify attack method and root cause, distinguishing confirmed facts from assumptions.
- Assess impact on people, accounts, devices, information, services, finances and operations.
- Assess reporting speed, escalation, evidence preservation, technical actions and communications.
- Determine whether the Phishing Email Checker produced useful and appropriately qualified results.
- Identify what worked, what caused delay/confusion and what should change.
- Assign corrective actions with owners, due dates and completion evidence.
- Update this Plan, detection rules, staff training and technical controls as required.
- Output: completed Appendix 5 and corrective actions tracked to completion.

9. EVIDENCE AND INCIDENCE RECORDS

- The IT Administrator must maintain a restricted incident case record.
- Evidence must be collected lawfully, proportionately and only to the extent reasonably necessary for security, investigation, legal or compliance purposes.

Evidence	Handling requirement
Original email and headers	Preserve in native/original format where possible; record how and when obtained. A screenshot alone may omit technical details.
Screenshots and user statement	Record date/time, source and what is depicted; avoid unrelated personal information.
Email/security/sign-in logs	Preserve through authorised tools; record source, time range and collector.
Endpoint alerts/files	Record device identifier, alert, file name/hash if available and action taken. Do not execute suspicious files.
Incident timeline	Record significant actions, decisions, notifications, responsible person and timestamp.
Storage and access	Use restricted storage; limit access to authorised responders/advisers; follow retention and secure disposal rules.

- Where evidence may be relevant to litigation, employment action, insurance or law enforcement, consult the appropriate legal adviser before altering or disposing of it. Record evidence access and transfers.

10. COMMUNICATIONS AND LEGAL/PRIVACY ASSESSMENT

10.1. Internal and external communications

- Internal: The IRL is responsible for coordinating internal updates. This includes telling employees what they need to do, which systems are affected, how to report concerns and where to obtain assistance. Employees should not circulate live malicious links or unnecessary personal information.

- External: Only management or an authorized spokesperson may communicate with customers, suppliers, regulators or media. Verify facts and recipients before sending any such communication. Further, obtain contact details independently of the suspicious message.

10.2. Data protection and legal assessment

- Where personal data may have been accessed, disclosed, altered, lost or otherwise compromised, the IRL must refer the matter promptly to management and the organisation's Data Protection Officer (if appointed) or legal adviser.
- They should assess whether the event constitutes a personal data breach, the nature and sensitivity of data, individuals affected, likely consequences, mitigation and applicable notification or communication duties under the applicable Data Protection Laws, regulations and other relevant laws.
- Not every phishing email is a personal data breach. A suspicious message received but not acted upon may not involve personal data compromise. Assessment must be based on the facts and applicable law.
- This Plan does not set a fixed statutory reporting deadline. The legal/privacy adviser must verify current requirements and circumstances before deciding whether, when and to whom notification is required.
- Contractual notification clauses, client confidentiality obligations, sector-specific requirements, insurance conditions and law-enforcement referral must also be considered. Record the assessment, decision, rationale, approver and notifications.

11. CLOSURE CRITERIA

The IRL may recommend closure when:

- The incident is contained and the known malicious pathway or attacker access has been removed or controlled.
- Affected accounts, devices and services are recovered or an approved recovery plan is in place.
- Available evidence and key decisions are recorded and stored securely.
- Impact and residual risks are assessed and escalated appropriately.
- Required management, legal/privacy and contractual assessments are completed or assigned.
- Affected users are informed of continuing precautions.
- The post-incident review is completed or scheduled with an owner and date.

Closure does not prevent reopening if new evidence emerges. The register must show closure date, approving person and outstanding corrective actions.

12. TRAINING, TESTING AND MAINTENANCE

- Staff should receive periodic phishing awareness guidance. The IRL should test this Plan at least annually, after material changes to email systems or roles, and after a significant incident.

Exercise	Scenario	Expected actions
1. No interaction	Employee receives suspicious supplier invoice email but does not click/open.	Report, preserve, log, assess, check recipients, quarantine confirmed copies, communicate if widespread and document closure.
2. Link clicked	Employee clicks a link but says no credentials were entered.	Establish actions/device, check downloads and endpoint/account alerts, assess isolation, check recipients, monitor and document.
3. Credentials disclosed	Employee enters work password and approves unexpected MFA prompt.	Immediate escalation, reset credentials, revoke sessions, inspect MFA/mailbox rules, check outbound messages/sign-ins, assess data exposure, recover and review.

- After each exercise, record whether the reporting route was known, severity appropriate, containment clear, evidence captured, legal/privacy triggers recognised and corrective actions assigned.

APPENDICES

OPERATIONAL TEMPLATES

APPENDIX 1 – PHISHING INCIDENT REPORTING FORM

To be completed by the employee/reporting person and uploaded on the incident reporting tab of the Phishing Email Checker. Do not delay urgent reporting because some details are unavailable.

Field	Information to complete
Incident ID	For IT / IRL use
Reporter name and contact	
Affected employee / mailbox	
Date and time received	
Sender display name and email	
Reply-to address (if different)	
Subject line	
Short description of message	
Link clicked?	☐ No ☐ Yes ☐ Unsure Time/details: _____
Attachment opened/downloaded?	☐ No ☐ Yes ☐ Unsure File/details: _____
Credentials/MFA entered or approved?	☐ No ☐ Yes ☐ Unsure Details: _____
Personal/client/business information disclosed?	☐ No ☐ Yes ☐ Unsure Type: _____
Payment or transaction made?	☐ No ☐ Yes ☐ Unsure Details/amount: _____
Device used	☐ Work laptop ☐ Personal device ☐ Mobile ☐ Other: _____
Unusual activity observed	
Original email/evidence preserved?	☐ Yes ☐ No ☐ Unable Storage: _____
Date/time reported and person notified	

Reporter confirmation: I have provided the information known to me, will preserve the message and follow IT instructions. I will not further interact with the suspicious content.

Reporter name/signature: _____ Date/time: _____

APPENDIX 2- INCIDENT INVESTIGATION CHECKLIST

Completed by the IT Administrator with the IRL.

Check	Action / evidence to record	Done / notes
☐	Assign incident ID; record report time, reporter and affected user.	
☐	Preserve original email and headers; record source and storage location.	
☐	Record sender, reply-to, subject, timestamps, displayed URLs and attachment names. Do not visit/open suspicious content.	
☐	Establish whether user clicked, opened, downloaded, replied, disclosed credentials/data, approved MFA or paid.	
☐	Identify affected mailbox, device, user and other recipients.	
☐	Review relevant email security alerts/message trace or equivalent logs, where available.	
☐	Review sign-in activity, MFA changes, unfamiliar devices and mailbox rules, where authorised.	
☐	Review endpoint protection alerts and possible downloads/execution, where available.	
☐	Run Phishing Email Checker; record result as supporting triage evidence only.	
☐	Determine whether incident is isolated or part of a wider campaign.	
☐	Assign provisional severity using Appendix 3; record rationale and escalation.	
☐	Decide containment actions, owner and timing; do not delay urgent containment.	
☐	Record facts, assumptions, gaps, decisions and next review time.	

Investigation findings: _____

_____

Investigator: _____ Date/time completed: _____

APPENDIX 3 – SEVERITY AND ESCALATION MATRIX

- *The IRL uses this matrix to assign severity.*
- *If uncertain, apply the higher level temporarily. The checker score does not determine severity.*

Severity	Indicators	Notify	Minimum response
LOW	Received only; no interaction; no evidence of compromise.	IT Administrator; IRL routine update.	Log, inspect, check recipients, quarantine confirmed malicious messages, record result.
MEDIUM	Link clicked or attachment opened; no known disclosure or confirmed compromise.	IT Administrator and IRL promptly.	Establish actions; check device/account alerts; assess downloads/execution; monitor; contain if indicated.
HIGH	Credentials/MFA disclosed; suspicious sign-in/mailbox activity; malware may have executed; sensitive data/payment details may be exposed.	Immediately: IT, IRL, management; legal/privacy adviser if relevant.	Reset credentials; revoke sessions; review MFA/mailbox rules; investigate endpoint/account; assess data, financial and business impact.
CRITICAL	Multiple accounts/systems compromised; material data exfiltration; successful fraudulent payment; major disruption or serious harm.	Immediately: management, IRL, IT; external/legal/privacy support as appropriate.	Management-led coordination; urgent containment; consider business continuity, bank contact, external specialists and applicable notifications.

Incident ID: _____ Assigned severity: _____ Date/time: _____

Decision-maker: _____ Rationale/evidence: _____

Persons notified: _____ Next review time: _____

Severity change history and reasons: _____

APPENDIX 4 – INCIDENT REGISTER

- *The IRL maintains this as the central register of reported incidents.*
- *It must be stored it in a restricted location. Do not include passwords or unnecessary sensitive personal information.*

Incident ID	Date/time reported	Reporter / affected user	Brief description	Severity	Status	Owner	Closure date
PH-2026-001							
PH-2026-002							
PH-2026-003							
PH-2026-004							
PH-2026-005							

- Suggested Status Values: Reported / Assessing / Containing / Eradicating / Recovering / Monitoring / Closed.

- Detailed case record should also contain:
  - Action/decision timeline;
  - Evidence location;
  - Affected accounts/devices;
  - Persons notified;
  - Containment, eradication and recovery actions;
  - Legal/privacy assessment;
  - Residual risk;
  - Corrective actions; and
  - Closure approver.

APPENDIX 5 – POST-INCIDENT REVIEW FORM

- *Completed by the IRL after containment and recovery.*
- *Use the review to improve controls and procedures.*

Review field	Details / findings
Incident ID and date(s)	
Review date and participants	
Incident summary	
Attack method and indicators observed	
Timeline: receipt, report, assessment, containment, eradication, recovery	
Affected users, accounts, devices, systems and information	
Business, financial, confidentiality or privacy impact	
Root cause (confirmed facts vs assumptions)	
What worked well?	
What did not work or caused delay/confusion?	
Was severity appropriate? Explain.	
Was the Phishing Email Checker useful? Limitations / false positives / false negatives?	
Were evidence and decisions adequately recorded?	
Legal/privacy/contractual assessment and decision, if applicable	
Corrective action 1: action / owner / due date / completion evidence	
Corrective action 2: action / owner / due date / completion evidence	
Corrective action 3: action / owner / due date / completion evidence	
Changes required to Plan, training or technical controls	
Review completed by / approval	

Closure recommendation: ☐ Close incident ☐ Keep open ☐ Reopen / escalate

IRL name/signature: _____ Date: _____